Hamza BAHALLOUL



Élève ingénieur en cybersécurité – Stage de fin d'études (PFE)
GRC (ISO 27001, EBIOS RM) – DevSecOps & Pentest – EASM & CTI

Disponible de janvier à juillet 2027 (6 mois), en présentiel en France ou au Maroc
Convention de stage : fournie par l'ENSA **Diplôme :** juillet 2027 (Bac+5)
Téléphone : +212 707 716 476 **Localisation :** El Jadida, Maroc
E-mail : hamzabahalloul1@gmail.com **Portfolio :** h-4mza.github.io/portfolio
LinkedIn : linkedin.com/in/hamza-bahalloul-a30189342 **GitHub :** github.com/h-4mza

Profil

Élève ingénieur en dernière année de **Cybersécurité et Confiance Numérique** (école d'ingénieurs, Bac+5, diplôme juillet 2027), orienté **gouvernance des risques** (EBIOS RM, ISO 27001), **DevSecOps** et **sécurité applicative**, avec une pratique de l'**EASM**, de la **Cyber Threat Intelligence** et de la forensique assistée par IA. Classé **8e (Top 10) au Cyber Quest CTF de SANS Institute** (72 h de sécurité offensive). J'ai conçu et développé seul un SaaS d'EASM/CTI en stage, ainsi que, en projets personnels, une plateforme de conformité « as code » et une application RAG multi-tenant que j'ai auditée, corrigée et instrumentée pour la détection. Je sais relier une vulnérabilité technique à un risque métier et restituer le résultat à des interlocuteurs techniques comme décisionnels.

Preuves clés : 8e place (Top 10) au Cyber Quest CTF de SANS Institute ; audit d'une application RAG multi-tenant (8 vulnérabilités, 2 critiques CVSS 9,1, correctifs vérifiés) ; analyse EBIOS RM de 10 scénarios et SoA sur les 93 contrôles ISO 27001:2022 ; SaaS d'EASM/CTI conçu seul en stage.

Formation

Cycle Ingénieur – Cybersécurité et Confiance Numérique **10/2024 – 07/2027**
École Nationale des Sciences Appliquées d'El Jadida (ENSA), école d'ingénieurs publique El Jadida, Maroc
Modules clés : tests d'intrusion et digital forensics ; gestion des risques et gouvernance de la sécurité SI ; sécurité des réseaux et des systèmes ; DevOps et sécurité du développement ; cloud ; sécurité OT/IoT et des modèles d'IA.

Cycle préparatoire intégré **10/2021 – 07/2024**
École Nationale des Sciences Appliquées d'El Jadida (ENSA) El Jadida, Maroc

Expériences professionnelles & compétitions

8e place (Top 10) – Cyber Quest CTF (compétition de 72 h) **10/2026**
SANS Institute Compétition internationale
- Épreuve internationale intensive : exploitation web & API, exploitation binaire (*buffer overflows*, chaînes ROP), rétro-ingénierie (*reverse engineering* de code obfusqué), *digital forensics* et cryptanalyse.

Stagiaire Ingénieur Cybersécurité – EASM & Cyber Threat Intelligence (2 mois) **07/2026 – 09/2026**
AZunix Rabat, Maroc
- Conception et développement, seul et de bout en bout, de **Cyber360**, plateforme SaaS multi-tenant d'EASM et de CTI répondant à deux problèmes : le *Shadow IT* (actifs exposés oubliés, sous-domaines, serveurs de test) et l'*alert fatigue* (listes interminables de vulnérabilités).
- **Security by design :** isolation stricte des données par client, authentification JWT avec rotation des refresh tokens, RBAC (Admin, Analyste, lecture seule) ; backend asynchrone FastAPI, Celery, Redis, PostgreSQL, 5 modules sous Docker Compose ; interface React 18 / TypeScript.
- **Risk Engine** déterministe (notation de type CVSS) croisant les vulnérabilités avec **MITRE ATT&CK** pour prioriser les menaces réelles ; corrélation CTI 237 fois plus rapide grâce à une hash map en mémoire (de 2,28 s à 9,6 ms sur un benchmark de 50 000 vulnérabilités).
- Détection de sites clones (anti-typosquatting) par fuzzing DNS et similarité (seuil d'alerte à 85 %) ; copilote **LLM (Gemini)** alimenté par des données déterministes (JSON) pour produire synthèses exécutives et plans de remédiation en limitant les hallucinations.

Stagiaire Réseaux et Sécurité – Sécurisation d'une infrastructure inter-sites **07/2025 – 08/2025**
TAQA Morocco El Jadida, Maroc
- Architecture réseau sécurisée reliant deux sites distants (**VLAN**, **VPN IPsec**) ; pare-feux **FortiGate** et politiques de contrôle d'accès granulaires.
- Centralisation des identités et des ressources (**Active Directory**, DHCP) ; maquettage et tests sous **GNS3** pour valider l'étanchéité des règles avant la mise en production.

Projets personnels et académiques

TenantGuard et GRC-as-Code : projets personnels réalisés en 2026, mettant en pratique les modules GRC, DevSecOps et sécurité applicative du cycle ingénieur. CheatTrace et NFTShieldX : projets académiques de fin d'année.

TenantGuard – API RAG multi-tenant : DevSecOps, Pentest & Détection **08/2026 – 10/2026**
Projet personnel – github.com/h-4mza/TenantGuard

- Application SaaS **RAG multi-tenant** volontairement vulnérable puis durcie (FastAPI, PostgreSQL, ChromaDB, Gemini, Docker).
- Pipeline **GitHub Actions** en 6 jobs : SAST (Semgrep), SCA (pip-audit), secrets (Gitleaks), scan d'image (Trivy, bloquant en cas de faille critique ou élevée corrigeable), DAST (OWASP ZAP, informatif), SBOM (Syft) ; actions épinglées par SHA.
- **Pentest web/API** (Burp Suite, scripts Python) : 8 vulnérabilités documentées dont 7 exploitées avec preuves (forge de jetons JWT, IDOR/BOLA cross-tenant, path traversal, fuite vectorielle cross-tenant dans le RAG, injection de prompt), dont 2 critiques (CVSS 9,1) ; rapport d'audit **CVSS v3.1** classé selon l'OWASP API Top 10 et l'OWASP Top 10 LLM.
- Remédiation puis vérification par rejeu de chaque exploitation, avec détection et correction d'une régression ; 25 tests automatisés (pytest).
- **7 règles de détection** mappées MITRE ATT&CK sur des logs structurés (Promtail, Loki, Grafana), provisionnées en code ; simulation d'intrusion : MTTD 46,5 s, 3 phases sur 4 détectées (dont 1 partielle) ; runbooks et post-mortem.

GRC-as-Code – Pilotage cybersécurité d'un centre d'imagerie médicale **07/2026 – 09/2026**
Projet personnel – étude de cas

- Problème traité : en santé, la GRC repose sur des fichiers Excel statiques, sans lien entre une faille (SecOps) et le registre des risques.
- Conformité traitée comme du code : risques, contrôles et matrices en **YAML**, versionnés sous Git, ingérés via une CLI (Typer) puis une API FastAPI (PostgreSQL), avec évaluation automatisée des contrôles.
- Parseur **SARIF** reliant les vulnérabilités réelles (ex. Trivy) aux scénarios de risque via MITRE ATT&CK : risque résiduel et maturité des contrôles recalculés en quelques secondes, contre plusieurs jours manuellement.
- Analyse **EBIOS RM** complète : 10 scénarios (ransomware sur PACS, exfiltration via VPN, compromission de la supply chain) ; évaluation des **93 contrôles ISO 27001:2022** et **SoA** prête pour audit.
- Couverture **NIS2, RGPD, HDS et NIST CSF 2.0** dans un tableau de bord CISO Streamlit (heatmap) ; synchronisation ITSM (Jira) en ligne de commande.

CheatTrace – Plateforme forensique de détection de fraude académique par IA **02/2026 – 05/2026**
Projet de fin d'année (2e année, filière CCN, ENSA)

- Analyse de copies d'examen manuscrites : **OCR multimodal** (Gemini), analyse stylométrique par NLP et architecture **multi-agents CrewAI** (Expert NLP, Analyste de Fraude Collaborative, Juge Forensique).
- Similarités sémantiques et lexicales (**SBERT**, **TF-IDF**), mémoire vectorielle **ChromaDB** ; cartographie des réseaux de triche par graphes (**NetworkX**, Louvain) : 1 225 paires comparées pour 50 étudiants.
- Validée sur 95+ investigations (copies 100 % IA, hybrides, authentiques, 2 clusters collaboratifs) ; présentée devant jury le 18 mai 2026.

NFTShieldX – Marketplace NFT décentralisée anti-contrefaçon **02/2025 – 05/2025**
Projet de fin d'année – équipe de 4, méthode Scrum (8 sprints)

- Smart Contracts Solidity (OpenZeppelin, protection contre la réentrance) sur Sepolia, Zero-Knowledge Proof pour la confidentialité, stockage IPFS ; détection de copies d'images (SIFT, FAISS, pHash) bloquant le minting ; audit de sécurité interne des contrats.

Compétences techniques

Gouvernance, risques & conformité : ISO/IEC 27001:2022, EBIOS RM, SoA, NIS2, RGPD, HDS, NIST CSF 2.0, analyse de risques, STRIDE.

Sécurité offensive & défensive : pentest web/API (Burp Suite, jwt_tool, ffuf), exploitation binaire (buffer overflow, chaînes ROP), reverse engineering, cryptanalyse, OWASP API & LLM Top 10, CVSS v3.1, MITRE ATT&CK, CTI, EASM, détection (Loki, Grafana), digital forensics, Kali Linux, Wireshark.

DevSecOps : Git, GitLab CI, Semgrep, Gitleaks, pip-audit, Trivy, OWASP ZAP, SBOM (Syft), SARIF, pytest, Docker, Docker Compose.

Développement : Python (FastAPI, Flask, Celery, SQLAlchemy, Typer, Pandas), SQL, JavaScript/TypeScript, React, Node.js, Java, C, Solidity.

Systèmes & réseaux : Linux, Windows, TCP/IP, VLAN, IPsec, FortiGate, Active Directory, DHCP, GNS3, Cisco Packet Tracer, virtualisation.

IA & données : LLMs (Gemini), RAG, CrewAI, NLP (SBERT, TF-IDF), OCR multimodal, ChromaDB, NetworkX, n8n, Machine Learning ; PostgreSQL, MySQL, MongoDB.

Certifications, distinctions, langues et engagements

Distinction : 8e place internationale (Top 10) – Cyber Quest CTF (SANS Institute, 10/2026)

Certifications : ISO/IEC 27001 Information Security Associate (SkillFront) | AWS Academy Graduate – Engineering Operations Technicians | Fortinet Certified Fundamentals Cybersecurity | ISC2 Candidate | Ethical Hacker (Cisco Networking Academy)

Langues : Arabe (maternelle) | Français (C1, langue d'enseignement) | Anglais (C1)

Associations : Akasec – 1337 CyberSecurity Club (bootcamp de cybersécurité) | Ship, association à but non lucratif (Trésorier)